

Cybersecurity Consulting Report

Strategic Defense and Incident Response



Docente: José Carlos Menezes
Discente: Tulani Souza

1. Sumário Executivo	1
2. Escopo e Metodologia	2
3. Arquitetura de Defesa (Camadas)	3
4. Monitoramento & SIEM	4
5. Resposta a Incidentes (NIST IR)	4
6. Recomendações (80/20) e Roadmap (30/90/180 dias)	4
7. Riscos, Custos e Assunções	
Riscos: dependência de equipe reduzida, limitação orçamentária	
Custos: Ferramenta SIEM básica + tempo de equipe.....	
8. Conclusão	5



1. Sumário Executivo

A LojaZeta enfrenta riscos de ataques direcionados ao ambiente web, incluindo SQL injection, XSS e brute-force em endpoints críticos como /login.

Nossa proposta entrega:

Arquitetura de defesa em camadas, incluindo controles perimetrais, segmentação de rede, hardening de hosts, segurança de identidade e backups testados.

Integração prática com Dozzle para monitoramento em tempo real de containers e visualização de logs, incluindo scripts de bloqueio/desbloqueio automático para conter ataques (defesa ativa).

Plano SIEM mínimo viável, consolidando logs de Nginx, Node.js e PostgreSQL.

Procedimentos de IR baseados no NIST, com runbooks claros para SQLi, XSS, brute-force e indisponibilidade.

Ganhos esperados: Redução de tempo de detecção (MTTD), maior eficiência de contenção, visibilidade centralizada e roamp de segurança factível dentro do orçamento.

2. Escopo e Metodologia

Cobertura: perímetro, rede, aplicação web, banco de dados e identidade.

Assunções: equipe reduzida (3 pessoas), orçamento limitado - priorização pelo princípio 80/20

3. Arquitetura de Defesa (Camadas)

Perímetro: Firewall em nuvem + WAF para inspeção de tráfego HTTP/HTTPS.

Rede: segmentação de containers (produção vs. Monitoramento)

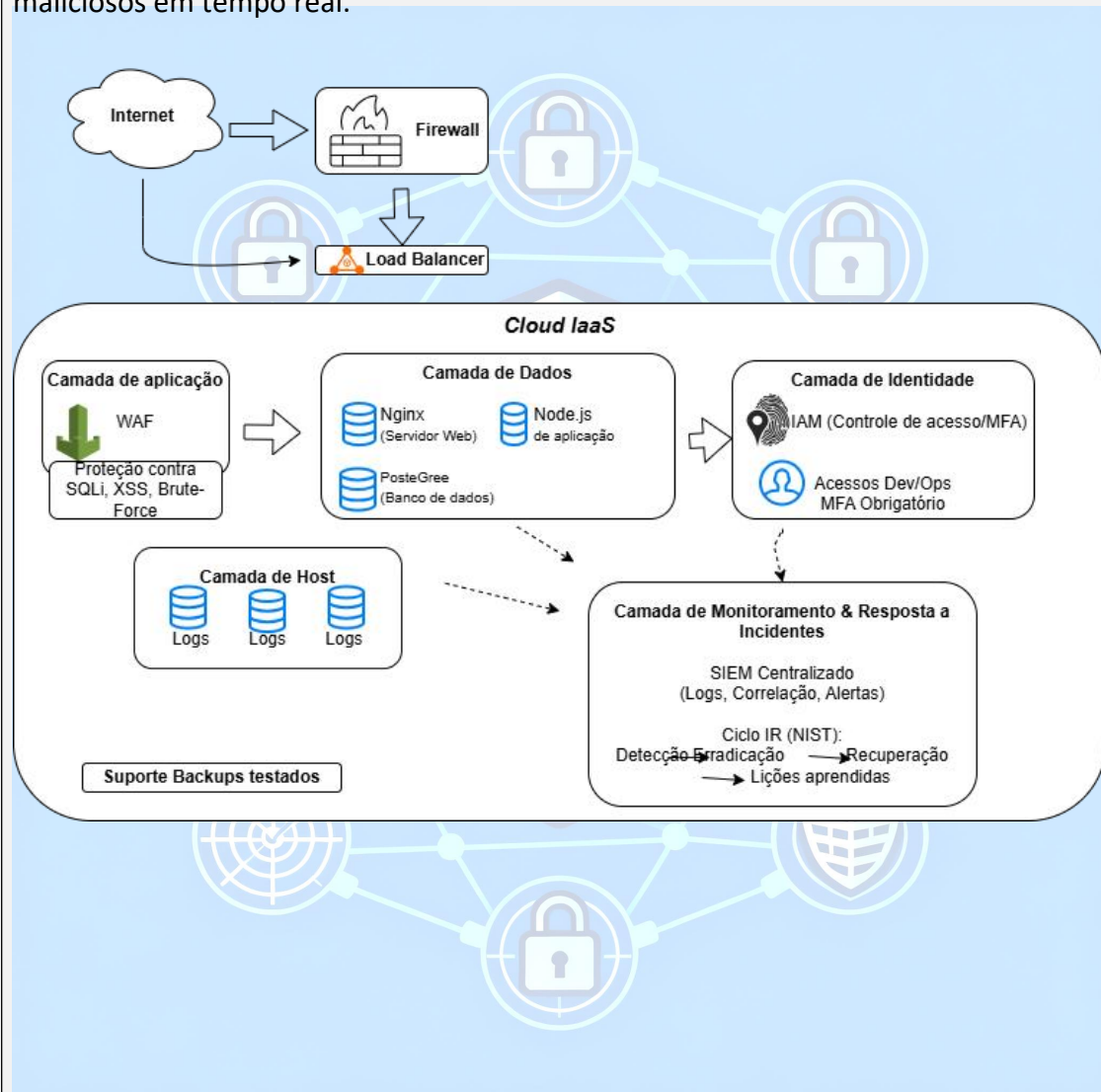
Host: Hardening de sistemas (Ubuntu, Node.js, PostgreSQL).

Aplicação: Validação de entrada, proteção contra SQLi/XSS, autenticação multifator.

Identidade: gerenciamento de privilégios mínimos

Backups: automação com testes periódicos de restauração.

Integração prática: uso de scripts no Dozzle para bloquear/desbloquear IPs maliciosos em tempo real.



4. Monitoramento & SIEM

- Fontes de log: Nginx (requisições e erros); Node.js (aplicação); PostgreSQL (queries suspeitas); Sistema operacional (auth, kernel, firewall); Dozzle (visualização em tempo real de containers e eventos de bloqueio/desbloqueio)
- Correlações e Alertas: Tentativas repetidas de login - alerta + bloqueio automático; Padrões de SQL injection/XSS detectados - alerta + script de contenção
- KPIs: MTTD (Mean Time to Detect) < 5 min ; MTTR (Mean Time to Respond) < 30 min; % de cobertura de logs > 80%

Exemplo de Alerta no SIEM:

Se ocorrerem 5 falhas consecutivas de login para o mesmo IP ou usuário dentro de 1 minuto, gerar alerta crítico de brute-force e acionar script de bloqueio automático.”

Outros casos:

SQLi → detectar padrões como " ' OR 1=1 " em parâmetros de requisição.

XSS → detectar presença de <script> no payload HTTP.

Alta taxa de erros 403/404 → sinalizar varredura automatizada.

5. Resposta a Incidentes (NIST IR)

Detecção: Dozzle + alertas de padrões suspeitos.

Contenção: scripts de bloqueio automático (iptables ou firewall em nuvem).

Erradicação: remoção de acessos maliciosos, patching e reforço de regras.

Recuperação: Restauração de serviços com backups testados.

Lições Aprendidas: runbooks atualizados após cada incidente.

Runbooks disponíveis: SQL injection; XSS; Brute-force em /login; Indisponibilidade de serviço

6. Recomendações (80/20) e Roadmap (30/90/180 dias)

- Quick wins(30 dias): Implantar Dozzle com scripts de bloqueio/desbloqueio; Centralizar logs básicos em SIEM mínimo viável (Elastic/Graylog); Reforçar autenticação e rate limiting no /login.
- Médio prazo (90 dias): Testar restauração de backups; Expandir monitoramento para DB e SO; Treinar equipe em IR (execução de runbooks).

Longo prazo (180 dias): WAF avançado com correlação de tráfego; Automação de alertas no SIEM; Revisão de arquitetura de identidade (MFA, RBAC granular).

7.Riscos, Custos e Assunções

Riscos: dependência de equipe reduzida, limitação orçamentária

Custos: Ferramenta SIEM básica + tempo de equipe

Assunções: stack de produção será mantida em IaaS; equipe de dev/ops disponível para execução do plano

8. Conclusão

A solução proposta oferece defesa em camadas prática e acessível, com foco em visibilidade, resposta rápida e resiliência.

O uso do Dozzle com bloqueio/desbloqueio em tempo real coloca a LojaZeta em um patamar acima do mínimo de segurança, dentro de seu orçamento.

2- Escopo de metodologia

Este projeto abrange a avaliação e proposta de solução para a defesa da infraestrutura web e aplicação da LojaZeta, incluindo:

- Avaliação dos riscos atuais e histórica de incidentes
- Proposta de arquitetura em camadas para proteção do perímetro à aplicação.
- Plano mínimo viável de monitoramento e alerta.
- Plano de resposta a incidentes baseado no framework NIST SP 800-61r2.
- Recomendações prioritárias e roadmap para implementação.

A análise considerou logs espalhados em instâncias, ausência de SIEM, orçamento restrito e time pequeno, levando a decisões que priorizam quick wins e soluções eficientes e escaláveis.

Um diagrama de arquitetura de defesa em camadas. No centro, há um escudo amarelo com uma borda vermelha, contendo o código binário "100010001110111". O escudo é rodeado por uma rede de pontos azuis conectados por linhas azuis. Ao redor desta rede, há oito ícones circulares: quatro cadeados fechados (topo, esquerda, direita e fundo) e quatro alvos (topo-direita, topo-esquerda, fundo-esquerda e fundo-direita).

3- Arquitetura de defesa em camada

Perímetro: Implementação do ModSecurity, um WAF open-source robusto, modular e altamente configurável, atuando no monitoramento e bloqueio em tempo real do tráfego HTTP(S). A utilização do OWASP CRS agrega regras automatizadas para proteção contra as principais vulnerabilidades web, reduzindo falsos positivos e otimizando o esforço operacional.

Rede: Segmentação da rede para isolamento de componentes críticos aliados a políticas rígidas de firewall.

Host: Hardening dos servidores com atualizações e configurações seguras.

Aplicação: Revisão e XSS.

Dados: Backups regulares implementados, recomendando-se testes periódicos de restauração.

Identidade: Controle de acesso baseado em autenticação multifator.

4- Monitoramento e SIEM

Fontes de logs integradas: ModSecurity (logs detalhados HTTP/S com identificação de Rule IDs dos ataques - ex. Rule ID 942100 para SQLi), Nginx, aplicação Node.js, PostgreSQL e sistemas operacionais. Sugestão de implementação de SIEM básico para centralizar e correlacionar logs, com alertas configurados para ataques detectados.

Métricas chave para acompanhamento:

MTTD (Mean Time To Detect)

MTTR (Mean Time To Respond)

Número de tentativas bloqueadas

Cobertura percentual dos logs coletados e monitorados

Um diagrama de segurança cibernética com um fundo azul claro. No centro, há um escudo branco com uma borda amarela e uma seta verde apontando para cima. O escudo contém o código binário "10001110111". Ao redor do escudo, há uma rede de pontos brancos conectados por linhas azuis. Nove ícones circulares estão distribuídos ao redor: três cadeados brancos (topo, esquerda, fundo), dois alvos brancos (direita, esquerda) e um escudo branco (fundo).

5- Resposta de incidente (NIST/ IR)

Aplicação do guia SP800-61r2 estruturando o plano com:

Preparação: definição de papéis, ferramentas e procedimentos.

Deteção e Análise: Uso do SIEM para identificar eventos com detalhamento fornecido pelo ModSecurity + CRS

Contenção: Bloqueio imediato no WAF e bloqueio de IPs suspeitos

Erradicação: Aplicação de patches, remoção de vetores e análise forense.

Recuperação: Restauração dos sistemas afetados a partir de backups validados.

Lições Aprendidas: Revisão pós-incidente para melhoria contínua.

Runbooks elaborados para SQLi, XSS e brute-force, com passos simplificados para equipe pequena.

6- Recomendações (80/20) e Roadmap (30/90/180 dias)

Prazo	Ações Prioritárias (Quick Wins e médio/longo prazo)	Responsáveis
30 dias	Ativar ModSecurity com OWASP CRS em modo blocking, iniciar testes de backup e restauração, configurar alertas no SIEM	Dev & Ops
90 dias	Implantar SIEM com regras customizadas, realizar hardening e treinamento	Segurança
180 dias	Revisão da política de identidade e MFA, automatizar resposta a incidentes	Gestão & Dev



7- Riscos, custo e assunções

Orçamento limitado pode restringir ampliação do time e ferramentas avançadas.

Dependência da manutenção e atualização contínua do CRS para minimizar falsos positivos e garantir eficácia.

Suposições sobre disponibilidade da equipe para treinamentos e adequação das ferramentas à stack atual.

8- Conclusão

A implementação da solução proposta elevará a LojaZeta para um patamar alinhado com melhores práticas de mercado, melhorando a resiliência a ataques comuns e a visibilidade sobre incidentes de segurança. O comprometimento com os próximos passos do roadmap e o monitoramento contínuo serão essenciais para o sucesso da estratégia.

Seção	O que escrever / desenvolver	Exemplos práticos
Sumário Executivo	Um parágrafo ou página que sintetiza os riscos mais críticos, a solução que você propõe e os benefícios esperados para o cliente (LojaZeta)	“A LojaZeta corre risco de vazamento de dados de clientes via SQLi e XSS; propomos uma arquitetura de defesa em camadas com WAF, monitoramento centralizado e runbooks de IR. Espera-se reduzir incidentes críticos em 80% em 3 meses.”
Escopo e Metodologia	Descrever exatamente o que você vai (e o que não vai) cobrir, qual abordagem usou, as bases teóricas (NIST, OWASP), suposições e limitações	“Cobrirá web, banco de dados e identidade; não entraremos em rede física; baseamo-nos no NIST IR + laboratório prático com WAF + Dozzle; assumimos equipe limitada e infra em IaaS.”
Arquitetura de Defesa (Camadas)	Para cada camada (perímetro, rede, host, aplicação, dados, identidade) explique quais controles você sugere, com justificativas técnicas	“No perímetro sugerimos firewall em nuvem e WAF ModSecurity para inspecionar tráfego HTTP. Na camada de aplicação, aplicar validações em backend + rate limiting. Para identidade: exigir MFA, RBAC mínimo.”
Monitoramento & SIEM	Quais logs serão capturados (ex: logs Nginx, logs de aplicação, logs do banco, logs de sistema), correlações desejadas, alertas específicos que serão criados, métricas (MTTD, MTTR, cobertura)	“Capturar logs de acesso do Nginx, erros da aplicação Node.js, queries suspeitas no PostgreSQL. Alertas: múltiplas falhas de login, padrões de <script>, SQL com OR '1'. Métricas: tempo médio para detectar < 15 min, cobertura mínima 80%.”
Resposta a Incidentes (NIST IR)	Para cada fase (Detecção, Contenção, Erradicação, Recuperação, Lições Aprendidas), explique o que será feito no contexto da LojaZeta, e	“Detecção via alertas do WAF/SIEM. Contenção: ativar bloqueio no WAF ou script de bloqueio. Erradicação: corrigir código vulnerável. Recuperação: restaurar do backup. Lições: rever

Seção	O que escrever / desenvolver	Exemplos práticos
	inclua runbooks resumidos para os tipos de ataque	controles, atualizar runbooks.”
Recomendações e Roadmap	Divida em curto, médio e longo prazo os projetos de segurança, priorizando o que gera impacto maior primeiro (princípio 80/20). Atribua responsáveis e prazos	“Nos primeiros 30 dias: ativar WAF, centralizar logs básicos, definir alertas. Nos próximos 90 dias: migrar para SIEM completo, treinar time. Até 180 dias: automação de resposta, dashboards executivos.”
Riscos, Custos e Assunções	Quais riscos existem (por exemplo: falso positivo, custo de equipe), que custos você prevê, e quais premissas você está assumindo	“Risco de bloqueios indevidos do WAF sem tuning. Custos de tempo da equipe e licença de SIEM. Assumimos que infra em IaaS permite instalar logs e regras personalizadas.”
Conclusão	Síntese final: o caminho a seguir, critérios de sucesso, próximos passos imediatos	“Com as medidas propostas, a LojaZeta ganhará visibilidade e proteção progressiva. O sucesso será medido por redução de incidentes críticos, métricas de detecção e resposta e testes regulares.”

Anexos:

```
PROBLEMS OUTPUT DEBUG CONSOLE TERMINAL PORTS
devcyber@Tulani:~/formacao-cybersec/modulo2-defesa-monitoramento/projeto-final/opcao1-hands-on/labs$ docker compose up
WARN[0000] /home/devcyber/formacao-cybersec/modulo2-defesa-monitoramento/projeto-final/opcao1-hands-on/labs/docker-compose.yml: the attribute 'version' is obsolete
, it will be ignored, please remove it to avoid potential confusion
[+] Running 5/5
  ✓ Network labs_labnet35 Created 0.1s
  ✓ Container dvwa Created 0.2s
  ✓ Container kali_lab35 Created 0.2s
  ✓ Container dozzle Created 0.2s
  ✓ Container waf_modsec Created 0.2s
Attaching to dozzle, dvwa, kali_lab35, waf_modsec
kali_lab35 | (root@1ae4c543b82e)-[/]
waf_modsec | /docker-entrypoint.sh: /docker-entrypoint.d/ is not empty, will attempt to perform configuration
waf_modsec | /docker-entrypoint.sh: Looking for shell scripts in /docker-entrypoint.d/
waf_modsec | /docker-entrypoint.sh: Launching /docker-entrypoint.d/01-check-low-port.sh
waf_modsec | /docker-entrypoint.sh: Launching /docker-entrypoint.d/10-generate-certificate.sh
waf_modsec | /usr/local/bin/generate-certificate: generating new certificate
dozzle | {"level":"warn","env":"DOZZLE_USERNAME","time":"2025-09-27T20:59:39Z","message":"Unexpected environment variable"}
dozzle | {"level":"warn","env":"DOZZLE_PASSWORD","time":"2025-09-27T20:59:39Z","message":"Unexpected environment variable"}
dozzle | {"level":"info","version":"v8.14.2","time":"2025-09-27T20:59:39Z","message":"Dozzle version v8.14.2"}
waf_modsec | Warning: Not placing -key in cert or request since request is used
waf_modsec | Warning: No -copy_extensions given; ignoring any extensions in the request
waf_modsec | /usr/local/bin/generate-certificate: generated /etc/nginx/conf/server.key and /etc/nginx/conf/server.crt
waf_modsec | /docker-entrypoint.sh: Launching /docker-entrypoint.d/10-listen-on-ipv6-by-default.sh
waf_modsec | 10-listen-on-ipv6-by-default.sh: info: Getting the checksum of /etc/nginx/conf.d/default.conf
waf_modsec | 10-listen-on-ipv6-by-default.sh: info: /etc/nginx/conf.d/default.conf differs from the packaged version
waf_modsec | /docker-entrypoint.sh: Sourcing /docker-entrypoint.d/15-local-resolvers.envsh
12e862beaf64 amir20/dozzle:latest "/dozzle" About a minute ago Up About a minute 0.0.0.0:9999->8080/tcp, [::]:9999->
8080/tcp dozzle
1ae4c543b82e labs-kali_lab35 "/bin/bash" About a minute ago Up About a minute
kali_lab35
6cebedac1d9c vulnerables/web-dvwa "/main.sh" About a minute ago Up About a minute 80/tcp
devcyber@Tulani:~/formacao-cybersec/modulo2-defesa-monitoramento/projeto-final/opcao1-hands-on/labs$ curl -s http://localhost:8080 | head -5
devcyber@Tulani:~/formacao-cybersec/modulo2-defesa-monitoramento/projeto-final/opcao1-hands-on/labs$ docker exec -it kali_lab35 /bin/bash
(root@1ae4c543b82e)-[/]
# nmap -sS -sV waf_modsec
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-28 23:02 UTC
Nmap scan report for waf_modsec (192.168.35.30)
Host is up (0.000000s latency).
rDNS record for 192.168.35.30: waf_modsec.labs_labnet35
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
8080/tcp  open  http    nginx
8443/tcp  open  ssl/http nginx
MAC Address: 2A:44:D5:A0:C7:3E (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.67 seconds

❌ docker-compose.yml X
formacao-cybersec > modulo2-defesa-monitoramento > projeto-final > opcao1-hands-on > labs > ❌ docker-compose.yml
3 services:
  Run Service
16 waf_modsec:
17   image: owasp/modsecurity-crs:nginx-alpine
18   container_name: waf_modsec
19   environment:
20     - BACKEND=http://dvwa:80 # para onde o WAF faz proxy_pass
21     - SERVER_NAME=localhost # hostname do WAF
22     - MODSEC_RULE_ENGINE=On # modo blocking (bloqueia ataques)
23     - MODSEC_RULE_ENGINE=DetectionOnly
24     # Níveis de paranoia (afinam detecção/bloqueio):
25     - BLOCKING_PARANOIA=1
26     - DETECTION_PARANOIA=1
PROBLEMS OUTPUT DEBUG CONSOLE TERMINAL PORTS
Nmap done: 1 IP address (1 host up) scanned in 12.67 seconds
(root@1ae4c543b82e)-[/]
# exit
exit
devcyber@Tulani:~/formacao-cybersec/modulo2-defesa-monitoramento/projeto-final/opcao1-hands-on/labs$ ls -la
devcyber@Tulani:~/formacao-cybersec/modulo2-defesa-monitoramento/projeto-final/opcao1-hands-on/labs$ docker compose up -d --force-recreate waf_modsec
WARN[0000] /home/devcyber/formacao-cybersec/modulo2-defesa-monitoramento/projeto-final/opcao1-hands-on/labs/docker-compose.yml: the attribute 'version' is obsolete
, it will be ignored, please remove it to avoid potential confusion
[+] Running 2/2
  ✓ Container dvwa Running 0.0s
devcyber@Tulani:~/formacao-cybersec/modulo2-defesa-monitoramento/projeto-final/opcao1-hands-on/labs$
```



```
details=
  accuracy="0" data="Matched Data: alert( found within ARGS:name: <script>alert("XSS")</script>"
  file="/etc/modsecurity.d/owasp-crs/rules/REQUEST-941-APPLICATION-ATTACK-XSS.conf" lineNumber="739"
  match="Matched 'Operator `Rx` with parameter `(?i)\b(?:eval|set(?:timeout|interval)|new[\s\x0b]+Function|
a(?:let|tob)|btoa|(?::prompt|import|t|con(?:firm|sole\.(?:log|dir)))|fetch)[\s\x0b]*[\\{\}]` against variable
`ARGS:name` (Value: `<script>alert("XSS")</script>` )"
  maturity="0" reference="o8,6v33,29t:htmlEntityDecode,t:jsDecode" rev="" ruleId="941390" severity="2"
  tags=
["modsecurity", "application-multi", "language-multi", "platform-nodejs", "attack-xss", "xss-perf-disable",
"paranoia-level/1", "OWASP_CRS", "OWASP_CRS/ATTACK-XSS", "capec/1000/152/242"]
  ver="OWASP_CRS/4.18.0"
  message="Javascript method detected"
,
details=
  accuracy="0" data="" file="/etc/modsecurity.d/owasp-crs/rules/REQUEST-949-BLOCKING-EVALUATION.conf"
  lineNumber="222"
  match="Matched 'Operator `Ge` with parameter `5` against variable `TX:BLOCKING_INBOUND_ANOMALY_SCORE`
(Value: `20` )"
  maturity="0" reference="" rev="" ruleId="949110" severity="0"
  tags=["modsecurity", "anomaly-evaluation", "OWASP_CRS"] ver="OWASP_CRS/4.18.0"
  message="Inbound Anomaly Score Exceeded (Total Score: 20)"
]
transaction.producer.components=["OWASP_CRS/4.18.0"] transaction.producer.connector="ModSecurity-nginx v1.0.4"
transaction.producer.modsecurity="ModSecurity v3.0.14 (Linux)" transaction.producer.secrules_engine="Enabled"
transaction.request.headers.Accept="*/ *" transaction.request.headers.Cookie="security=low"
transaction.request.headers.Host="dvwa" transaction.request.headers.User-Agent="curl/8.15.0"

h1</center> <hr><center>nginx</center> </body> </html> "
transaction.response.headers.Access-Control-Allow-Headers=""
transaction.response.headers.Access-Control-Allow-Methods="GET, POST, PUT, DELETE, OPTIONS"
transaction.response.headers.Access-Control-Allow-Origin=""
transaction.response.headers.Access-Control-Max-Age="3600" transaction.response.headers.Connection="keep-alive"
transaction.response.headers.Content-Length="146" transaction.response.headers.Content-Type="text/plain"
transaction.response.headers.Date="Mon, 29 Sep 2025 15:39:44 GMT" transaction.response.headers.Server="nginx"
transaction.response.http_code="403" transaction.server_id="a2ee9f7f6984d2c4886cdef38581516e14bfe79c"
transaction.time_stamp="Mon Sep 29 15:39:44 2025" transaction.unique_id="17591603840.887199"
```

docker-compose.yml X

formacao-cybersec > modulo2-defesa-monitoramento > projeto-final > opcao1-hands-on > labs > docker-compose.yml

```
3 services:
16   waf_modsec:
```

```
20     - BACKEND=http://dvwa:80 # para onde o WAF faz proxy_pass
21     - SERVER_NAME=localhost # hostname do WAF
22     #- MODSEC_RULE_ENGINE=On # modo blocking (bloqueia ataques)
23     - MODSEC_RULE_ENGINE=DetectionOnly
24     # Níveis de paranoia (afinam detecção/bloqueio):
25     - BLOCKING_PARANOIA=2
```

PROBLEMS OUTPUT DEBUG CONSOLE TERMINAL PORTS

```
bilitties/xss_r/?name=%3Cscript%3Ealert%28%22XSS%22%29%3C/script%3E" \
-H "Host: dvwa" \
-H "Cookie: security=low" \
-w "Status: %{http_code}"\n"
```

```
<html>
<head><title>403 Forbidden</title></head>
<body>
</body>
</html>
Status: 403
```

```
devcyber@Tulani:~/formacao-cybersec/modulo2-defesa-monitoramento/projeto-final/opcao1-hands-on/labs$ docker exec kali_lab35 curl -s "http://waf_modsec:8080/vulnera
```

```
bilitties/xss_r/?name=%3Cscript%3Ealert%28%22XSS%22%29%3C/script%3E" \
-H "Host: dvwa" \
-H "Cookie: security=low" \
-w "Status: %{http_code}"\n"
```

```
<html>
<head><title>403 Forbidden</title></head>
<body>
<center><h1>403 Forbidden</h1></center>
<hr><center>nginx</center>
```

0 0 0

Ln 22, Col 8 Spaces: 2 UTF-8 LF {} Compose Go Live



Dozzle

Hosts > docker-desktop

labs

dozzle

dwwa

kali_lab35

waf_modsec

Hosts e Containers

☆ waf_modsec

owasp/modsecurity-crs:nginx-alpine

09/29/2025 03:35:49 PM

2025/09/29 15:35:49 [error] 597#597: *15 [client 192.168.35.11] ModSecurity: Access denied with code 403 (phase 2). Matched "Operator 'Ge' with parameter '5' against variable 'TX:BLOCKING_INBOUND_ANOMALY_SCORE' (Value: '20') [file "/etc/modsecurity.d/owasp-crs/rules/REQUEST-949-BLOCKING-EVALUATION.conf"] [line "222"] [id "949110"] [rev ""] [msg "Inbound Anomaly Score Exceeded (Total Score: 20)"] [data ""] [severity "0"] [ver "OWASP_CRS/4.18.0"] [maturity "0"] [accuracy "0"] [tag "modsecurity"] [tag "anomaly-evaluation"] [tag "OWASP_CRS"] [hostname "dwwa"] [uri "/vulnerabilities/xss_r/"] [unique_id "175916014970.449704"] [ref ""], client: 192.168.35.11, server: localhost, request: "GET /vulnerabilities/xss_r/?name=%3Cscript%3Ealert%28%22XSS%22%29%3C/script%3E HTTP/1.1", host: "dwwa"

09/29/2025 03:35:49 PM

192.168.35.11 - - [29/Sep/2025:15:35:49 +0000] "GET /vulnerabilities/xss_r/?name=%3Cscript%3Ealert%28%22XSS%22%29%3C/script%3E HTTP/1.1" 403 146 "-" "curl/8.15.0" "-"

09/29/2025 03:35:49 PM

transaction.client_ip="192.168.35.11" transaction.client_port=33104 transaction.host_ip="192.168.35.30"

Diferenciar maiúsculas/minúsculas Considerar acentuação Palavras inteiras Ocorrência 5 de 19

☆ waf_modsec

owasp/modsecurity-crs:nginx-alpine

09/29/2025 03:49:54 PM

name=%3Cscript%3Ealert%28%22XSS%22%29%3C/script%3E HTTP/1.1" 403 146 "-" "curl/8.15.0" "-"

transaction.client_ip="192.168.35.11" transaction.client_port=37334 transaction.host_ip="192.168.35.30"

transaction.host_port=8080

transaction.messages=[

details=

accuracy="0" data="Matched Data: XSS data found within ARGS:name: <script>alert("XSS")</script>"

file="/etc/modsecurity.d/owasp-crs/rules/REQUEST-941-APPLICATION-ATTACK-XSS.conf" lineNumber="83"

match="detected XSS using libinjection." maturity="0"

reference="v33,29t:utf8toUnicode,t:urlDecodeUni,t:htmlEntityDecode,t:jsDecode,t:cssDecode,t:removeNulls"

rev="" ruleId="941100" severity="2"

tags=

["modsecurity", "application-multi", "language-multi", "platform-multi", "attack-xss", "xss-perf-disable", "paranoia-level/1", "OWASP_CRS", "OWASP_CRS/ATTACK-XSS", "capec/1000/152/242"]

ver="OWASP_CRS/4.18.0"

message="XSS Attack Detected via libinjection"

,

details=

accuracy="0" data="Matched Data: <script> found within ARGS:name: <script>alert("XSS")</script>"

file="/etc/modsecurity.d/owasp-crs/rules/REQUEST-941-APPLICATION-ATTACK-XSS.conf" lineNumber="110"

match="Matched 'Operator 'Rx' with parameter '(?i)<script>[>]*(\\s)*?' against variable 'ARGS:name' (Value: '<script>alert("XSS")</script>')"

maturity="0"

reference="00,8v33,29t:utf8toUnicode,t:urlDecodeUni,t:htmlEntityDecode,t:jsDecode,t:cssDecode,t:removeNulls"

941100

Destacar todas Diferenciar maiúsculas/minúsculas Considerar acentuação Palavras inteiras Ocorrência 8 de 8 Atingido o início da página, continua

☆ waf_modsec

owasp/modsecurity-crs:nginx-alpine

09/29/2025 03:49:44 PM

localhost, request: "GET /vulnerabilities/xqli/?id=1'+OR+'1'='1'--+&Submit=Submit HTTP/1.1", host: "dwwa"

09/29/2025 03:49:44 PM

192.168.35.11 - - [29/Sep/2025:15:49:44 +0000] "GET /vulnerabilities/xqli/?id=1'+OR+'1'='1'--+&Submit=Submit HTTP/1.1" 403 146 "-" "curl/8.15.0" "-"

09/29/2025 03:49:44 PM

transaction.client_ip="192.168.35.11" transaction.client_port=37322 transaction.host_ip="192.168.35.30"

transaction.host_port=8080

transaction.messages=[

details=

accuracy="0" data="Matched Data: s8s0s found within ARGS:id: 1' OR '1'='1'-- "

file="/etc/modsecurity.d/owasp-crs/rules/REQUEST-942-APPLICATION-ATTACK-SQLI.conf" lineNumber="46"

match="detected SQLi using libinjection." maturity="0" reference="v30,17" rev="" ruleId="942100"

severity="2"

tags=

["application-multi", "language-multi", "platform-multi", "attack-sqli", "paranoia-level/1", "OWASP_CRS", "OWASP_CRS/ATTACK-SQLI", "capec/1000/152/248/66"]

ver="OWASP_CRS/4.18.0"

message="SQL Injection Attack Detected via libinjection"

,

details=

accuracy="0" data="" file="/etc/modsecurity.d/owasp-crs/rules/REQUEST-949-BLOCKING-EVALUATION.conf"

lineNumber="222"

match="Matched 'Operator 'Ge' with parameter '5' against variable 'TX:BLOCKING_INBOUND_ANOMALY_SCORE' (Value: '5')"

maturity="0" reference="" rev="" ruleId="949110" severity="0"

942100

Destacar todas Diferenciar maiúsculas/minúsculas Considerar acentuação Palavras inteiras Ocorrência 11 de 11 Atingido o início da página, cont

